Hackeando el Miedo:

Construye, Ataca y Destruye tu Propio SOC Lab con IaC

Automatizando entornos de ciberseguridad en Azure con Terraform y Microsoft Sentinel

Microsoft Azure | HashiCorp Terraform | Microsoft Sentinel | Ansible

Carlos Solís — Microsoft MVP | IBM Champion

📢 Anuncios Parroquiales



Preguntas

Estaré atento al **canal de #preguntas del bootcamp** durante toda la charla.



Enlaces

Todos los enlaces y recursos se compartirán **al finalizar** la presentación.



Sin miedo

No hay preguntas tontas. Si lo piensas tú, lo piensan otras 50 personas.

🤔 La pregunta de hoy

¿Cómo puede un analista SOC L2 practicar detección y respuesta con ataques realistas…

sin esperar a TI, sin tocar producción y sin una factura infinita?

Para responderla, contestaremos:

- ¿Qué es IaC y por qué me importa?
- ¿Qué se construye y cuánto cuesta?
- ¿Cómo veo mis pruebas como incidentes en Sentinel?
- ¿Cómo lo destruyo todo al terminar?

PRESENTACIÓN DEL ORADOR

Sobre Mí

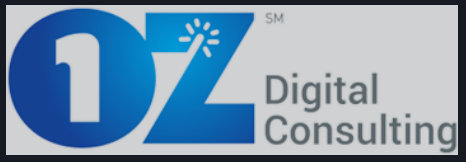
Carlos Solís Salazar

- 🏢 **Geo Practices Lead** de Infraestructura y Seguridad en **OZ Digital Consulting**.
- 🏅 **Microsoft MVP** (Azure / Seguridad) & **IBM Champion** en Terraform.
- 🦇 Miembro activo de la **Fundación Comunidad DOJO**.
- 🌐 **Global AI Community Panamá Chapter** & Líder de [Microsoft Azure Panamá].









¿Por qué un Analista SOC Debería Escribir Código?

❌ La Frustración Tradicional

- **Dependencia burocrática:** Semanas esperando que TI o Cloud Ops apruebe y cree una VM.
- **Miedo a romper producción:** Imposible probar malware o exploits en ambientes corporativos.
- **Ambientes estáticos y obsoletos:** Laboratorios desactualizados que no reflejan ataques modernos.

⚡ La Ventaja del Analista Moderno

- **Autonomía absoluta:** Levantas tu propio entorno de pruebas cuando lo necesitas.
- **Pensar como el adversario:** Los atacantes automatizan en la nube; la defensa debe automatizarse.
- **Empoderamiento técnico:** Si sabes cómo se declara la nube, sabes exactamente dónde buscar el rastro del atacante.

"No necesitas ser programador para usar IaC; necesitas IaC para ser un analista sin límites."

Infraestructura como Código para Mortales

Dejar de hacer 250 clics manuales en el Portal de Azure

🖱️ El Enfoque Imperativo (Clics)

"Entra al portal, busca VM, selecciona tamaño, configura red, crea DCR, asocia Sentinel..."

- Lento, agotador y propenso a errores humanos.
- Imposible de reproducir de forma idéntica dos veces.
- Si algo falla: ¿en qué clic te equivocaste?

📜 El Enfoque Declarativo (El Menú)

"Imagina un restaurante donde pides tu orden por escrito:"

- **Tú (El Comensal):** Escribes en un archivo de texto qué necesitas (1 Linux, 1 Windows, 1 Sentinel).
- **Terraform (El Mesero):** Lleva tu pedido ordenado a Azure.
- **Azure (La Cocina):** Prepara los recursos con precisión milimétrica.

Regla clave: Tú solo declaras el *ESTADO DESEADO*. Terraform se encarga del *CÓMO*.

Tu Propio Campo de Entrenamiento

Para cazar amenazas con maestría, necesitas un lugar donde romper cosas

01

Validar Reglas KQL

¿Tus consultas analíticas de Sentinel alertan a tiempo? Pruébalas generando eventos reales de autenticación y ejecución de procesos.

02

Simulación MITRE ATT&CK

Ejecuta técnicas de fuerza bruta (T1110), creación de usuarios (T1136) y reconocimiento sin temor a impactar operaciones corporativas.

03

Telemetría Multinivel

Aprende a correlacionar eventos Syslog de Linux, Security Events de Windows, logs de contenedores AKS y auditorías de Key Vault.

"La teoría te dice cómo debería sonar la alarma; el laboratorio te enseña qué hacer cuando empieza a sonar."

El Superpoder de "Destruir"

La regla de oro: paga por horas de uso, no por descuidos de fin de semana

$300 - $700 USD*

El Laboratorio Tradicional Olvidado

Máquinas virtuales, clústeres y servicios encendidos 24/7 durante un mes completo porque "daba flojera volver a configurarlos".

Factura sorpresa asegurada a fin de mes.

~$5 - $15 USD*

El Laboratorio Efímero con IaC

Despliegas en la mañana, ejecutas tus pruebas, capturas la telemetría en Sentinel y destruyes todo con un solo comando al finalizar el día.

Pagas únicamente por las 3 o 4 horas de práctica real.

* Estimaciones ilustrativas (todos los módulos encendidos todo el mes vs. una sesión de 3-4 h). No hay cotización validada: verifica en la calculadora de precios de Azure.

`terraform apply` ➔ *Pruebas y Detección* ➔ `terraform destroy`

La Arquitectura de Nuestro Laboratorio en Azure

Una superficie de ataque realista y telemetría centralizada

🖥️ Endpoints Víctimas

- **Windows Server 2022:** AD DS, IIS, logs 4625 y 4688 con CLI.
- **Ubuntu 22.04 LTS:** Apache, PostgreSQL, autenticación Syslog.

☁️ Cargas Modernas

- **App Service Linux:** Endpoint HTTP y auditoría web.
- **Azure Kubernetes (AKS):** Container Insights y auditoría de clúster.

🔐 Acceso & Secretos

- **Azure Key Vault:** Private Endpoint y DNS privado.
- **Auditoría estricta:** Registro de cada lectura o intento fallido de secreto.

🛡️ SIEM & Ingesta

- **Azure Monitor Agent (AMA):** DCR específicas por SO.
- **Log Analytics + Sentinel:** Workspace centralizado para consultas KQL.

🔄 *Automatización: Terraform despliega la infraestructura y ejecuta scripts benignos de generación de actividad al finalizar el aprovisionamiento.*

Modularidad Total: Los "Interruptores" de Terraform

Adapta el laboratorio a tus necesidades y presupuesto sin tocar el código base

🎛️ Componentes On/Off

En `terraform.tfvars` activas o desactivas componentes:

- `create_windows_vm = true/false`
- `create_linux_vm = true/false`
- `create_aks = true/false`
- `create_app_service = true/false`

Un `false` destruye el recurso si ya existía para evitar costos residuales.

🚀 Módulos Avanzados

Capacidades de seguridad listas para habilitar:

- `enable_ansible`: Despliegue de AD, IIS, Apache y PostgreSQL.
- `enable_sentinel_analytics`: 13 reglas analíticas e incidentes.
- `enable_sentinel_playbooks`: SOAR con Logic Apps.
- `enable_sentinel_notebooks`: Azure ML para Threat Hunting.
- `enable_defender_for_servers`: Defender for Servers P1 + MDE.

🔒 Protección Perimetral

Superficie de ataque blindada por defecto:

- `admin_source_cidr = "x.x.x.x/32"` : Solo tu IP pública tiene acceso a SSH, RDP, Key Vault y la API de AKS.
- Sin puertos de administración abiertos al mundo. Excepción deliberada: el endpoint HTTPS de App Service es público para practicar ataques web.

Red Segura y Aislamiento de Secretos

Segmentación estricta y almacenamiento protegido de credenciales en Azure

🌐 Topología de Red (`network.tf`)

- **VNet Segmentada (`10.20.0.0/16`):** Tres subredes con propósitos aislados:
  - `vm` (`10.20.1.0/24`): Servidores víctimas Windows y Linux.
  - `aks` (`10.20.2.0/24`): Clúster Kubernetes con CNI Overlay.
  - `private_endpoints` (`10.20.3.0/24`): Enlace privado a servicios PaaS.
- **Network Security Groups:** Reglas restrictivas para puertos de administración (22, 3389).
- **Zona DNS Privada:** `privatelink.vaultcore.azure.net` vinculada a la VNet.

🔐 Bóveda Segura (`key_vault.tf`)

- **Cero contraseñas en código o disco:**
  - `tls_private_key`: Genera dinámicamente el par RSA para SSH.
  - `random_password`: Genera contraseñas Windows seguras y únicas.
- **Private Endpoint:** El tráfico hacia Key Vault no sale a internet; viaja por una IP privada de la subred `10.20.3.0/24`.
- **Autorización RBAC estricta:** Acceso denegado por defecto en la red pública.
- **Auditoría Completa:** Diagnósticos hacia `AZKVAuditLogs` para detectar lecturas o intentos fallidos 404.

Endpoints Víctimas y Auditoría de Seguridad

Sistemas operativos configurados para telemetría profunda en el SOC

🪟 Windows Server 2022 (`compute.tf`)

SKU: `Standard_D2s_v6` con Managed Identity.

- **Auditoría Avanzada (`Configure-WindowsAudit.ps1`):** Extensión de script que habilita auditoría de logons (4625) y creación de procesos (4688) con *captura completa de argumentos de línea de comandos*.
- **Active Directory (Ansible):** Controlador de dominio y bosque `lab.example.test` (AD DS y DNS Server).
- **Servidor IIS:** Logs horarios de peticiones web en formato W3C.
- **Azure Monitor Agent (AMA):** Telemetría hacia `SecurityEvent`, `Event` y `W3CIISLog`.

🐧 Ubuntu 22.04 LTS (`compute.tf`)

SKU: `Standard_D2s_v6` con Managed Identity.

- **Cloud-Init:** Asegura `rsyslog` y dependencias base al arrancar.
- **Servicios Empresariales (Ansible):** Servidor web Apache y motor de base de datos PostgreSQL.
- **Auditoría SQL Completa:** PostgreSQL configurado con `log_statement = 'all'` para auditar cada query transaccional.
- **Rsyslog dedicado:** Redirige logs de Apache (`local6`) y PostgreSQL (`local5`) hacia el agente AMA en la tabla `Syslog`.

Cargas Cloud Nativas: AKS y App Service

Superficie de ataque moderna en Kubernetes y PaaS empresarial

Azure Kubernetes Service (`aks.tf`)

SKU: Free Tier con 2 nodos `Standard_D4s_v6`.

- **Red y Acceso:** Azure CNI Overlay, balanceador Standard y Azure RBAC integrado con Microsoft Entra ID.
- **Container Insights:** Extensión AMA especializada para K8s que recolecta logs de pods (`ContainerLogV2`), eventos (`KubeEvents`) e inventario (`KubePodInventory`).
- **Auditoría Administrativa:** Diagnostic settings de la API de Kubernetes hacia `AKSAuditAdmin` para auditar creaciones de pods, namespaces y escalación de privilegios en el clúster.

Azure App Service (`app_service.tf`)

SKU: Plan Linux B1 con Managed Identity.

- **Endpoint HTTPS Directo:** Superficie web pública para probar ataques web modernos (escaneo, directory traversal, inyección SQL).
- **Telemetría Web Dedicada:** Exporta cinco categorías de diagnóstico hacia Log Analytics:
  - `AppServiceHTTPLogs`: IP cliente, método, URI solicitada, status code y User-Agent.
  - `AppServiceConsoleLogs` y `AppServiceAuditLogs`: Auditoría de publicación y logs de plataforma.

La "Fontanería" del SOC: DCRs y Workspace Centralizado

Tubería de telemetría moderna sin agentes heredados ni clics manuales (`monitoring.tf`)

1. Data Collection Rules (DCR)

Filtrado quirúrgico en el origen:

- `dcr-windows`: Filtros XPath precisos para Security (4625, 4688, 4720..4738), System/Application y logs W3C de IIS.
- `dcr-linux`: Streams Syslog dedicados (auth, daemon, kern, `local5` PostgreSQL, `local6` Apache).
- `dcr-aks`: Logs y eventos de pods.

2. PaaS & Activity Log

Diagnósticos a Log Analytics:

- **Key Vault:** Auditoría en `AZKVAuditLogs`.
- **App Service:** HTTP y consola en `AppService*`.
- **AKS:** Auditoría de API en `AKSAuditAdmin`.
- **Suscripción:** `AzureActivity` con 8 categorías de cambios ARM (etiquetas, RBAC, NSG).

3. Workspace Centralizado

Control y correlación (`soc-l2-law`):

- **Workspace único:** Correlación cruzada entre VMs, contenedores, web y secretos.
- **Control de presupuesto:** Retención de 30 días y cuota diaria de 1 GB (no es un tope de facturación garantizado).
- **Autenticación local deshabilitada:** Acceso exclusivo mediante Microsoft Entra ID y RBAC.

Detección y Casos en Sentinel / Defender XDR

13 reglas analíticas programadas con creación automática de incidentes (`sentinel.tf`)

🚨 13 Reglas Analíticas Programadas

- **Severidades High y Medium:** Diseñadas específicamente para que los incidentes alcancen un *Priority Score* ≥ 15 y aparezcan directamente en la vista **Casos / Incidentes** de Microsoft Defender XDR.
- **Frecuencia Rápida (`PT5M`):** Las reglas analíticas se evalúan cada 5 minutos con ventanas de búsqueda de 15 a 30 minutos, detectando los eventos del script casi al instante.
- **Mapeo de Entidades:** Asignación de `Host`, `Account` e `IP` para que Defender construya el grafo del incidente y correlacione activos.

📊 Automatización y Workbook Visual

- **Regla de Automatización (`azurerm_sentinel_automation_rule`):** Intercepta incidentes cuyo título contiene `LAB-` y les aplica automáticamente la etiqueta `SOC-L2-Lab`.
- **Workbook Interactivo del Taller:** Despliega automáticamente el panel "*SOC L2 Lab - Eventos de seguridad generados*" con paneles KQL por prueba.
- **Hunting Queries guardadas (`sentinel_hunting.tf`):** `HUNT-01` procesos LOLBAS/PowerShell sospechosos y `HUNT-02` logons anómalos y movimiento lateral.

Respuesta Automatizada (SOAR): Playbooks en Sentinel

Logic Apps para enriquecimiento y triaje automático de incidentes (`sentinel_playbooks.tf`)

⚡ Logic Apps de Respuesta (Playbooks)

Desplegadas mediante plantillas ARM con **Managed Identity**:

- **Playbook 1: Enriquecimiento (`enrich`):**
  - Se ejecuta al crearse el incidente.
  - Inyecta automáticamente un comentario estructurado con el contexto del taller, detalles del vector de ataque y recomendaciones SOC L2.
- **Playbook 2: Triaje y Clasificación (`triage`):**
  - Cambia el estado del incidente a `Active`.
  - Asigna las etiquetas `SOC-L2-Lab` y `Taller` para filtrado rápido.

🔐 Permisos y Asignaciones de Rol RBAC

Seguridad nativa sin contraseñas ni conexiones API manuales:

- **Identidad Administrada de Logic Apps:** Recibe el rol `Microsoft Sentinel Responder` sobre el grupo de recursos para operar sobre incidentes.
- **Service Principal de Sentinel (`Azure Security Insights`):** Recibe el rol `Microsoft Sentinel Automation Contributor` para invocar los playbooks.
- **Regla de Automatización:** Orquesta la ejecución secuencial de ambos playbooks tras validar el título `LAB-`.

Caza de Amenazas con Jupyter Notebooks en Azure ML

Entorno analítico con MSTICPy y sincronización automática de cuadernos (`sentinel_notebooks.tf`)

🧠 Azure Machine Learning para el SOC

Infraestructura de análisis avanzado provisionada por Terraform:

- **Azure ML Workspace:** Con Storage Account, Key Vault y Application Insights dedicados.
- **Compute Instance (`Standard_DS2_v2`):** Instancia de cómputo lista para ejecutar cuadernos Jupyter con librerías de ciberseguridad (MSTICPy, Pandas, Kqlmagic).
- **Acceso Zero-Trust:** La Managed Identity de la Compute Instance recibe `Log Analytics Reader` sobre `soc-l2-law`: consultas KQL directas sin credenciales ni tokens expuestos.

📓 Cuadernos Sincronizados Automáticamente

Terraform sube los notebooks al file share de Azure ML:

- `SOC-L2-Eventos.ipynb`: verificación de ingesta por tabla y marcadores `SOC-L2-Pxx`.
- `SOC-L2-Caza.ipynb`: correlaciona marcadores con incidentes `LAB-Pxx`, alertas y línea de tiempo del `RunId`.
- `SOC-L2-Analisis-Logs.ipynb`: investigación forense por prueba (Windows, Linux, web, Key Vault, AKS) y matriz de hallazgos MITRE.

El Motor de Simulación: Generar Logs al Desplegar

Evita el "síndrome del SIEM vacío" con actividad benigna automatizada (`log_generation.tf`)

⚙️ ¿Cómo Opera el Script?

- **Paso final del despliegue:** Orquestado mediante `terraform_data` y `local-exec` ejecutando `Invoke-SocLabLogGeneration.ps1` al finalizar el `apply`.
- **Espera activa de salud:** No dispara eventos a ciegas; espera primero que las VM reporten `Heartbeat` y AKS reporte `KubePodInventory`.
- **Sin depender de SSH/RDP:** Se ejecuta desde el equipo administrador vía Azure CLI usando `az vm run-command` y `az aks command invoke`; no necesita puertos de administración abiertos para operar.
- **Repetición flexible:** Cambiar `log_generation_trigger` en `terraform.tfvars` vuelve a ejecutar la simulación en el siguiente apply.

🛡️ Trazabilidad y Seguridad

- **Marcadores únicos:** Cada ejecución firma sus pruebas como `SOC-L2-Pxx-<RunId>` para aislarlas y auditarlas con precisión milimétrica.
- **100% Inocuo y Efímero:** Actividad benigna controlada (cuentas falsas, pods efímeros, etiquetas desechables) que limpia sus rastros al terminar.
- **Consultas KQL listas:** Genera automáticamente un archivo `<RunId>-consultas.kql` en `%TEMP%` con las consultas exactas para copiar y pegar en Sentinel.
- **Modo Verificación:** El parámetro `-Verify` consulta la API de Log Analytics hasta confirmar que cada marcador llegó a su tabla.

Matriz de los 13 Escenarios Prácticos del Laboratorio

Cobertura completa mapeada a técnicas y tácticas del adversario

ID	Escenario / Prueba de Detección	Severidad	Táctica MITRE ATT&CK	Tabla en Sentinel
P02	Fuerza bruta / Password spraying en Windows	High	Credential Access (T1110)	`SecurityEvent (4625)`
P15	Manipulación anómala de cuentas y grupos AD	High	Persistence / PrivEsc (T1136, T1098)	`SecurityEvent (4720..4738)`
P04B	Fuerza bruta SSH y su en Linux	High	Credential Access (T1110, T1078)	`Syslog (sshd / su)`
P03	Creación de procesos sospechosos con CLI	Medium	Execution (T1059)	`SecurityEvent (4688)`
P05	Escaneo web, path traversal y sondeo en App Service	Medium	Discovery / Initial Access (T1190, T1595)	`AppServiceHTTPLogs`
P07	Intento de acceso no autorizado en Key Vault	Medium	Credential Access (T1552)	`AZKVAuditLogs`
P08	Modificaciones administrativas en Kubernetes	Medium	Persistence (T1098)	`AKSAuditAdmin`
P09	Modificación sospechosa de etiquetas ARM	Medium	Impact / Defense Evasion (T1496)	`AzureActivity`
P10	Evento de advertencia o pods anómalos en AKS	Medium	Execution (T1610)	`KubeEvents / ContainerLogV2`
P11	Peticiones HTTP anómalas en Apache	Medium	Discovery (T1595)	`Syslog (local6)`
P12	Peticiones HTTP sospechosas en IIS	Medium	Discovery (T1595)	`W3CIISLog`
P13	Fallo de autenticación en PostgreSQL	Medium	Credential Access (T1110)	`Syslog (local5)`
P14	Evento sospechoso en Application Log	Medium	Defense Evasion (T1562)	`Event (Application)`

Un Vistazo al Motor: HCL es Más Fácil de lo que Crees

Quitando el miedo: leer Terraform es como leer inglés básico

```
# Regla Analítica Programada con Incidente (sentinel.tf)
resource "azurerm_sentinel_alert_rule_scheduled" "lab" {
  for_each                   = local.sentinel_rules
  log_analytics_workspace_id = azurerm_log_analytics_workspace.soc.id
  display_name               = each.value.display_name
  severity                   = each.value.severity
  query                      = each.value.query
  query_frequency            = "PT5M"

incident {

create_incident_enabled = true

}

}
```

🔍 ¿Qué estamos viendo aquí?

- **1 bloque crea 13 reglas:** Mediante `for_each`, un único bloque declara todos los casos de detección sin duplicar código.
- **Incidentes Automáticos:** Con `create_incident_enabled = true`, cada alerta dispara un caso real en Defender XDR.
- **Evaluación ágil:** `query_frequency = "PT5M"` evalúa los logs cada 5 minutos tras correr el script.

"Si puedes leer un archivo de configuración o una regla KQL, ya sabes leer Terraform."

✅ ¿Qué necesito para construirlo? (1/2)

☁️ En Azure

- **Suscripción exclusiva de laboratorio** (Defender y Azure Activity actúan a nivel de suscripción).
- Roles **Contributor** + **User Access Administrator** (o **Owner**).
- **13 proveedores de recursos registrados** de antemano (Compute, Network, SecurityInsights, Security, Logic, MachineLearningServices…).
- **Cuota** en `eastus2`: unas 12-16 vCPU Dsv6, 2 vCPU DSv2 y 2-3 IP públicas.

💻 En tu equipo

- **Terraform ≥ 1.9 y < 2** y proveedor AzureRM 5.10.0.
- **Azure CLI** con `az login` y la suscripción seleccionada.
- Tu **IP pública /32** en `admin_source_cidr`.
- `kubectl` + `kubelogin` para entrar a AKS con Entra ID.
- Git y PowerShell.

✅ ¿Qué necesito para construirlo? (2/2)

🧩 Según el módulo que actives

- **Ansible:** WSL 2 con distribución `Ubuntu` y Python ≥ 3.12, y salida TCP/22 hacia las VM.
- **Playbooks:** autorizar el conector `azuresentinel` tras el primer apply.
- **Notebooks:** Azure CLI autenticado para la subida automática.
- **Defender for Servers:** alcance de suscripción y costo adicional.

🔐 Seguridad del estado

- El `tfstate` guarda la **clave SSH y la contraseña de Windows**.
- **Nunca** en OneDrive/Dropbox ni en Git; `*.tfvars` tampoco se sube.
- Para equipos: backend remoto cifrado en Azure Blob con bloqueo.

Tu Misión Para Hoy: Construye, Caza y Comparte

El conocimiento que no se practica se olvida en 48 horas

Paso 1

Clona el Repositorio

Haz fork o clona el repositorio del laboratorio con todo el código Terraform y scripts listos para usar.

```
git clone https://github.com/soysoliscarlos/sentinel-soc-lab.git
```

Paso 2

Despliega tu Lab

Inicia sesión con tu Azure CLI y levanta tu campo de entrenamiento con un solo flujo de Terraform (la primera vez toma un buen rato).

```
terraform apply
```

Paso 3

Caza en Sentinel

Conéctate, investiga los eventos en Sentinel usando KQL y destruye el entorno al terminar.

```
terraform destroy
```

🏆 **El Reto de la Sesión:** Despliega tu lab este fin de semana, toma captura de tus incidentes en Sentinel y publícala en LinkedIn etiquetando a **Carlos Solís** con el hashtag **#SOCLabIaC**.

¡Gracias por su Tiempo y Pasión!

Espacio para Preguntas y Respuestas (Q&A)

👤 **Orador:** Carlos Solís

🏅 **Reconocimientos:** Microsoft MVP | IBM Champion

🌐 **Conectemos:** LinkedIn: **/in/soysoliscarlos**

📦 **Repositorio del Lab:** github.com/soysoliscarlos/sentinel-soc-lab

🤝 **Comunidad Azure:** meetup.com/microsoft-azure-panama

"El miedo se hackea con conocimiento, curiosidad y código. ¡Vayan y construyan su laboratorio!"